

Col- Assessment tool-03

Name : M. Manasvi

Regno : 192311299

Course : ITA140

Midway through a penetrating test, the client's CEO verbally tells to "go ahead and test that system too", but it isn't in the Signed Statement of Work.

Explain the legal risk of proceeding, referencing the concept of authorization and applicable Computer Misuse Laws.

Introduction:

During a penetration test, an ethical hacker must only test the systems that are included in the signed statement of work (SOW) or the written authorization provided by the client. Even though the CEO verbally gives permission to test another system, it is not legally safe to proceed without updating the official agreement.

i concept of authorization

Authorization is the formal permission given by the system owner to perform security testing. In ethical hacking written authorization is essential because it defines

- Which systems can be tested
- The scope of testing
- The testing methods allowed

A verbal instruction from CEO doesn't change the legal scope of penetration test. Without authorization, additional

System is considered out of scope

2. Defining Hacker

Hackers are classified into three types

- White hat : works with proper authorization
- Black hat : Gains unauthorized access to system
- Gray hat : May access without permission but usually without malicious intent.

iii. Ethics of ethical hacking

- Obtain explicit authorization before testing
- Stay within the approved scope
- protects confidentiality, integrity & availability
- Act honestly, responsibly and professionally

Proceeding without updating the SOW violates the ethical principle of operating only within the authorized scope.

Authorization and legal system

Authorization is the legal granted by the system owner to perform penetration testing. The SOW is the primary legal document that defines

- systems that can be tested
- types of test allowed
- time period of testing

Many countries have computer misuse laws that prohibit unauthorized access, including

- Computer Fraud and Abuse Act (CFAA) - United States
- Computer Misuse Act (CMA) 1990 - United Kingdom
- Information Technology (IT) Act, 2000 - India

Under these laws, accessing or attempting to access a computer system without proper authorization may be considered a criminal offense, regardless of good intentions.

Legal Risks of Proceeding

Proceeding without updating the written agreement can result in

- Unauthorized access under computer misuse laws
- Civil lawsuits if the additional testing causes damage.
- Criminal liability in certain jurisdictions
- Breach of contract because the tester exceeds the agreed scope.

Proper & Ethical Disclosure

Responsible disclosure means communicating security findings in a legal and professional manner.

- 1) Inform the CEO that the requested system is outside the current scope.

- 2) Request a written amendment to the statement of work or obtain formal written authorization
- 3) Being testing only after the updated agreement has been signed
- 4) Document all findings and report vulnerabilities responsibly to the client.

Conclusion

According to foundational principles of ethical hacking, an ethical hacker must always operate with proper authorization, follow professional ethics, comply with computer misuse laws, and practice responsible disclosure. Even though CEO verbally authorizes additional testing, ethical hacker should not proceed until the SOW is approved.